

Roadmap v5.1 — Reliability, Multi-Akun & Partner Terbatas

Status dokumen: rencana. **Belum ada kode yang diubah.** **Menggantikan:** v5 (19 Agu 2026). Perubahan pokok ada di bagian 2. **Basis:** roadmap v4 (Fase 1–4 selesai), kode aktual `wa-gateway` / `wa-api` / `wa-ui`, dokumen review eksternal, dan keputusan hasil diskusi 19 Agu 2026.

1. Target yang dikunci

Level	Status	Isi
Level 1 — Internal Stable	Target aktif	Tidak kehilangan pekerjaan karena restart atau gangguan sesaat
Level 2 — Partner Ready (terbatas)	Target aktif, setelah Level 1 teruji	Komunitas internal, jumlah kecil, multi-akun : tiap partner memakai nomor WhatsApp sendiri
Level 3 — Public	Ditunda, tidak dicoret	Dievaluasi hanya setelah Level 2 teruji waktu dan banyak kasus. Perkiraan: bukan dalam 1 tahun ke depan

Level 2 di sini **berbeda** dari definisi dokumen review. Bukan "banyak penyewa berbagi satu nomor", melainkan **satu akun = satu nomor WhatsApp milik partner sendiri**. Konsekuensinya justru menyederhanakan sebagian masalah (kuota harian tidak lagi diperebutkan) dan memperberat sebagian lain (kustodian sesi, isolasi antar akun).

2. Perubahan dari v5

- K1 terjawab:** Level 2 dikejar, Level 3 ditunda. Fase bersyarat di v5 kini menjadi fase nyata dengan syarat masuk yang jelas.
- Level 2 = multi-akun.** Ini keputusan arsitektur baru; bagian 7–10 seluruhnya baru.
- account_id masuk skema Fase 6** — sekarang nyaris gratis, mahal kalau di-retrofit.
- Percobaan dua nomor masuk Fase 5** — untuk mengukur biaya memori nyata dan menjawab pertanyaan LID per-akun sebelum skema dikunci.
- Portal partner: Cloudflare Access;** panel superadmin tetap Tailscale-only, **proses terpisah**.
- Registrasi partner di luar X200MA** (web app GAS) dengan verifikasi manual.
- Lampiran integrasi GAS** (bagian 11) — partner berbasis Google Apps Script punya tiga batasan teknis yang mengubah rancangan.

3. Temuan yang mendasari seluruh rencana (ringkas)

Terverifikasi di kode, bukan dugaan:

#	Temuan	Bukti
T1	Antrian outbound in-memory	<code>wa-gateway/src/outbound/queue.js</code> — <code>const queue = []</code>
T2	Tidak ada idempotency	<code>enqueue()</code> push tanpa cek <code>request_id</code>
T3	State pesan tidak persisten	<code>message_log</code> tanpa <code>request_id/message_id</code>
T4	Webhook inbound tanpa retry	<code>wa-api</code> — <code>catch { log.error(...) }</code>
T5	<code>/health</code> menjawab hidup, bukan siap	<code>wa-api /health</code>
T6	Shutdown tidak menunggu pekerjaan	<code>SIGINT</code> menutup server & MQTT saja

Tambahan yang tidak ada di dokumen review:

- **queued adalah janji yang tidak dijamin.** Ack `queued` → HTTP 200 → dokumentasi menulis "jangan kirim ulang" → item hanya di memori. Restart = pesan hilang, dan aplikasi sudah dilarang mengulang. `ack_timeout` juga dilaporkan `queued`.
- **Retry hanya untuk `rate_limited`.** Kegagalan `sendMessage()` langsung `failed:send_error`, padahal itu kelas paling transient (WiFi X200MA sering drop).
- **Clean session MQTT.** `clientId` unik per proses tanpa `clean:false` ⇒ pesan yang di-publish saat subscriber mati hilang meski QoS 1.
- **Fitur yang mati sekarang:** pendaftaran pengguna baru `kitaCatat` (`no_inbound_history`), `notifyGroupMembers`, dan kegagalan `warmup_daily_limit` yang senyap.
- **Cache route check 6 jam** tanpa jalur invalidasi.
- **Aset paling mahal bila hilang:** `auth_session/`, `clients.json`, `identity_map`. Status backup belum diverifikasi.

4. Keputusan

Sudah diputuskan:

Kode	Keputusan
K1	Target: Level 1 + Level 2 terbatas. Level 3 ditunda
K6	Level 2 berbentuk multi-akun , satu nomor per partner
K7	Portal partner di balik Cloudflare Access ; panel superadmin Tailscale-only, proses terpisah
K8	Registrasi partner lewat web app GAS di luar X200MA , verifikasi manual oleh superadmin
K3	Sesi MQTT tetap <code>clientId</code> unik + clean session; lubangnya ditutup di sisi gateway (Fase 7)

Masih terbuka — memengaruhi bentuk Fase 6:

Kode	Pertanyaan	Catatan
K2	Setelah antrian durable, aplikasi diberi ack susulan, atau cukup bisa menanyakan <code>GET /messages/{request_id}?</code>	Yang kedua jauh lebih murah, tidak mengubah aplikasi yang ada
K4	Bolehkah perubahan menuntut penyesuaian di kitaCatat/AdaptLearn?	Rekomendasi: tidak . Semua perbaikan di belakang kontrak yang sama
K5	Berapa lama pesan tertunda masih bermakna?	Menentukan TTL antrian dan kapan masuk dead-letter. Notifikasi yang datang 6 jam terlambat bisa lebih membingungkan daripada tidak datang
K9	Penyimpanan isi pesan di <code>outbound_messages</code> — disetujui? Retensinya berapa lama?	Menyimpan teks pesan = isi percakapan tersimpan di disk. Dengan multi-akun, itu isi percakapan partner

5. Prinsip

1. **Perbaiki yang mati dulu, baru yang rapuh.**
2. **Jangan pernah membohongi pemanggil.** Status yang dilaporkan harus sesuai kenyataan.
3. **Penegakan aturan di antrian, bukan di UI.** Menyembunyikan field bukan pembatasan.
4. **Permukaan partner adalah daftar tertutup.** Kalau endpoint-nya tidak ada, tidak ada yang bisa ditembus.
5. **Setiap fase bisa di-rollback** dan tidak menuntut perubahan di aplikasi pemakai.
6. **Tidak menambah infrastruktur baru** tanpa masalah nyata yang tidak bisa diselesaikan tanpanya.
7. **Verifikasi sebelum ubah.** Setiap fase punya daftar data yang harus diambil dulu.

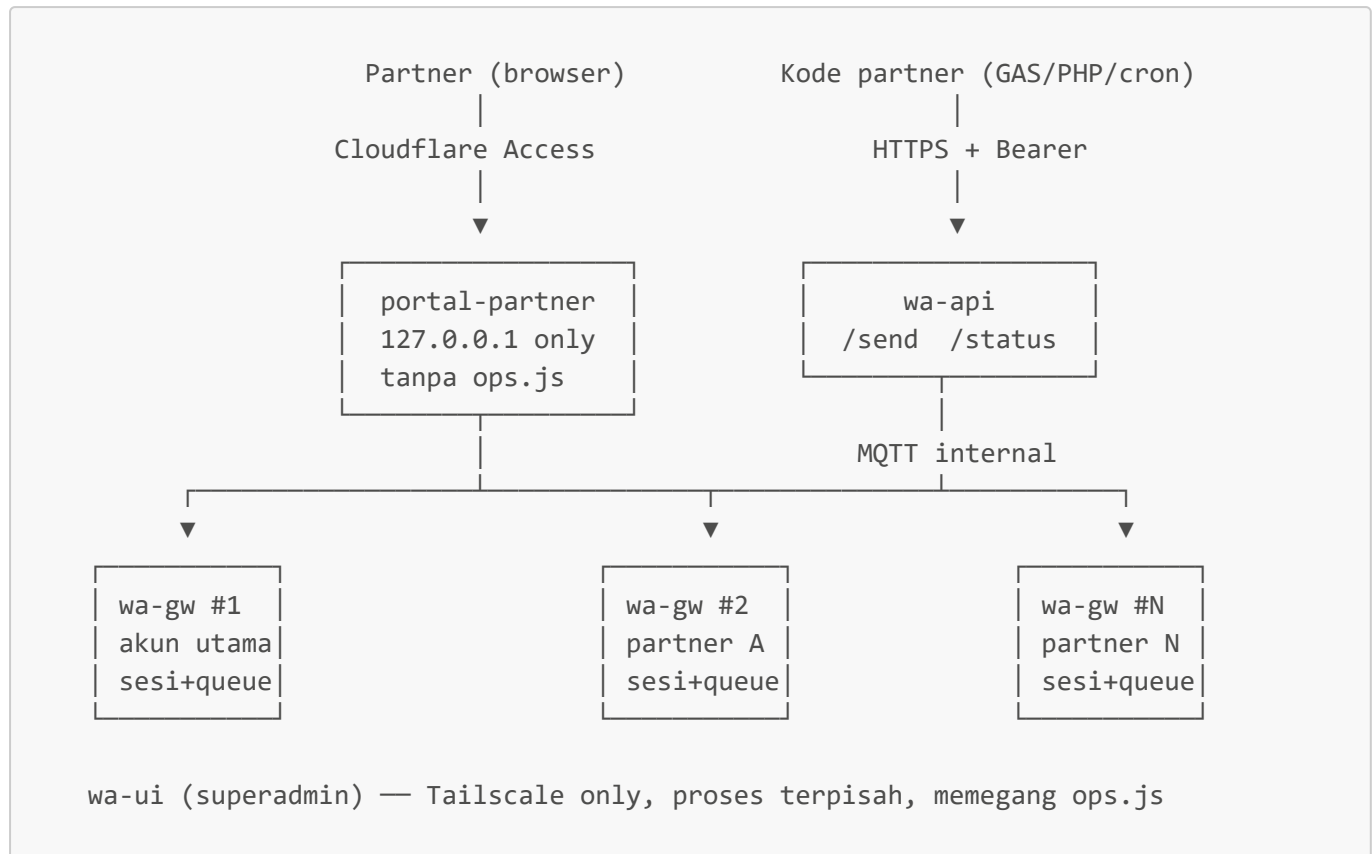
6. Tiga jalur yang harus dibedakan

Kekeliruan paling mudah terjadi kalau ketiganya dicampur. Pengamanannya berbeda karena pemakainya berbeda.

Jalur	Pemakai	Arah	Pengaman
Portal partner	manusia, lewat browser	partner → X200MA	Cloudflare Access + validasi JWT
POST /send	kode partner (GAS, PHP, cron)	partner → X200MA	Bearer token. Publik, tanpa Access
Webhook & route check	X200MA memanggil aplikasi partner	X200MA → partner	Aturan SSRF di sisi kita

`waapi.simbiot.id/send` sudah publik lewat Cloudflare Tunnel dan sudah terbukti — kitaCatat di shared hosting tidak bisa menjangkau IP Tailscale, dan GAS berada di posisi yang sama. **Access tidak boleh dipasang di jalur ini**; Access untuk login manusia, memasangnya di `/send` akan mematikan seluruh pemanggil mesin.

7. Arsitektur target Level 2 (multi-akun)



Prinsip isolasi:

- **Satu proses PM2 per akun**, dengan direktori sesi, batas memori, dan antrian outbound sendiri. Crash, kebocoran memori, atau logout satu akun tidak menyentuh akun lain.
- **Antrian outbound per akun**. Kalau digabung, webhook partner yang lambat menahan giliran kitaCatat.
- **Kuota & rate limit per akun**. Masalah "500 pesan/hari diperebutkan semua aplikasi" hilang dengan sendirinya.
- **Partner tidak pernah menyentuh MQTT**. MQTT tetap murni internal; ACL Mosquitto tidak dibuka untuk siapa pun di luar proses milik Anda.
- **Sakelar mati per akun** yang bekerja seketika, tanpa merestart akun lain.

8. Keamanan multi-akun

8.1 Ancaman dan penanganannya

Ancaman	Penanganan
Pemalsuan identitas Access (Cf-Access-Authenticated-User-Email bisa dipalsukan)	Portal wajib memvalidasi JWT Cf-Access-Jwt-Assertion terhadap kunci publik Cloudflare dan memakai email dari JWT, bukan dari header teks. Tanpa ini, Access hanya dekorasi
Portal dijangkau tanpa melewati Access	Portal bind ke 127.0.0.1 saja — bukan IP Tailscale. Pastikan tidak ada hostname lain yang mengarah ke port itu

Ancaman	Penanganan
Partner mencapai fungsi operator	<code>ops.js</code> (PM2, <code>.env</code> , berkas) tidak boleh berada dalam proses yang sama dengan halaman partner. Dua proses, dua port, dua basis kode
SSRF lewat URL webhook — partner mengarahkan webhook ke <code>127.0.0.1:8091</code> , ke IP Tailscale, atau ke perangkat lain di tailnet, lalu membaca hasilnya dari log	Wajib <code>https://</code> + domain publik; tolak resolusi ke loopback, RFC1918, link-local, dan CIDR Tailscale <code>`100.64.0.0/10`</code> ; resolusi DNS diperiksa saat permintaan dikirim (bukan hanya saat disimpan, karena DNS rebinding); ikuti maksimal satu redirect lalu validasi ulang tujuannya; isi respons tidak pernah ditampilkan mentah ke partner — cukup kode status
QR sebagai jalur eskalasi — siapa pun yang bisa memicu pairing lalu memindai QR memperoleh kendali penuh atas WhatsApp akun itu	QR hanya muncul untuk akun milik sesi yang sedang login, atas aksi eksplisit; TTL sangat pendek; dikosongkan segera setelah tersambung atau kedaluwarsa; topic MQTT QR per-akun dengan ACL (sekarang <code>wa/gateway/qr</code> retained dan terbaca oleh subscriber mana pun dengan izin <code>wa/#</code>); setiap permintaan pairing masuk audit log yang bisa dilihat partner
Satu akun membaca data akun lain	<code>account_id</code> sebagai kunci wajib di seluruh kueri portal; tidak ada endpoint yang menerima <code>account_id</code> dari input pengguna
Partner menaikkan batasnya sendiri	Nilai yang bisa diatur partner divalidasi ulang di server terhadap batas keras. Jeda antar pesan, aturan hanya-balas-inbound, dan batas per tujuan tidak bisa diubah partner
Token API bocor	Token disimpan sebagai hash SHA-256 (sudah berlaku), ditampilkan sekali saat dibuat, bisa dicabut seketika dari portal maupun panel superadmin
Backup keluar dari mesin membawa sesi partner	Backup wajib terenkripsi. Ini satu-satunya tempat enkripsi-saat-istirahat memberi manfaat nyata

8.2 Sisa risiko — tidak bisa dihapus, harus dinyatakan di depan

1. **Anda kustodian sesi WhatsApp partner.** Root di X200MA = akses membaca dan mengirim sebagai partner. Enkripsi sesi di disk tidak menolong, karena proses harus bisa membacanya sendiri saat boot tanpa Anda hadir. **Kendali terakhir tetap di tangan partner:** menu *Perangkat Tertaut* di WhatsApp bisa mereka putuskan kapan saja tanpa izin Anda — sampaikan ini terbuka, karena ini jaminan yang jujur dan lebih kuat daripada janji apa pun.
2. **Anda satu-satunya operator.** Logout 401 partner tidak bisa dipulihkan tanpa Anda **dan** tanpa mereka. Kalau Anda tidak tersedia seminggu, layanan partner mati seminggu. Ini kapasitas manusia, bukan masalah kode — dan inilah yang menentukan batas jumlah partner, bukan spesifikasi mesin.
3. **Satu mesin, satu koneksi rumah.** Tidak ada redundansi. WiFi X200MA tercatat sering drop.
4. **Library tidak resmi, melanggar ToS WhatsApp.** Blokir nomor bisa terjadi kapan saja. Rate limit adalah pengaman operasional, **bukan** jaminan bebas blokir.

Keempatnya wajar untuk komunitas internal yang saling kenal — **asal tertulis di depan**, bukan diasumsikan partner sudah paham.

9. Onboarding partner

9.1 Alur

1. Partner membuka web app GAS (di luar X200MA – nol permukaan baru di mesin Anda)
isian: nama, organisasi, email (untuk Access), nomor WA, keperluan
↓
2. GAS membangkitkan kode unik DAFTAR-XXXXXX
dan menampilkan tautan wa.me berisi kode itu
↓
3. Partner mengirim kode tersebut ke nomor gateway
↓
4. Gateway mengonsumsi pesan berkode (TIDAK diteruskan ke menu pilihan aplikasi),
mencatat kecocokan kode ↔ pengirim
↓
5. Superadmin menerima notifikasi Telegram: isian form + konfirmasi kode diterima
↓
6. Verifikasi manual → email ditambahkan ke Cloudflare Access
→ akun dibuat di panel superadmin
↓
7. Pesan "pendaftaran disetujui" dikirim ke partner
↓
8. Partner login ke portal, memindai QR untuk nomornya sendiri, membuat token,
mengisi webhook URL

9.2 Kenapa bentuknya begini

- **Form tidak bisa berada di balik Access** — calon partner belum ada di daftar email, jadi tidak akan pernah melihat formnya. Menaruhnya di hostname tanpa Access berarti membuka kembali endpoint publik tanpa autentikasi di X200MA. Karena itu form berjalan di GAS.
- **Langkah 3 bukan formalitas.** Nomor partner yang baru mendaftar belum pernah mengirim pesan ke bot, sehingga outbound ke sana akan ditolak `no_inbound_history` — persis masalah OTP kitaCatat. Satu pesan berkode itu sekaligus: membuktikan nomor benar miliknya, menautkan pengirim ke isian form, dan **membangun riwayat inbound** sehingga langkah 7 bisa terkirim. Aturan `no_inbound_history` tidak dilawan, tapi dipakai sebagai alat verifikasi.
- **Jangan melewati aturan itu untuk mempermudah pendaftaran.** Kalau dilewati, form publik berubah menjadi relay: siapa pun mengisi nomor orang lain berulang kali, dan gateway Anda yang mengirimkan pesannya.
- **Notifikasi ke superadmin lewat Telegram, bukan WhatsApp** — bot `wa-watchdog` sudah ada, tidak memakan kuota harian gateway, dan tidak menambah beban pada nomor yang sedang dijaga.

9.3 Dua daftar yang harus tetap sinkron

Setelah ini identitas partner ada di dua tempat: daftar email Cloudflare Access, dan akun di portal.

Ketidaksesuaian menghasilkan gejala yang membingungkan — atau lebih buruk: akun dicabut di portal tapi emailnya masih di Access.

Prosedur pencabutan ditulis dengan urutan tetap:

- | | |
|---|-------------------------|
| 1. Cabut email di Cloudflare Access | (hentikan akses portal) |
| 2. Nonaktifkan akun di panel superadmin | (hentikan proses akun) |
| 3. Cabut token API akun tersebut | (hentikan /send) |

Access tidak menyentuh /send. Mencabut email partner **tidak** mematikan token API mereka — itu langkah nomor 3, dan tidak boleh terlewat.

10. Batas kemampuan partner (daftar tertutup)

Partner boleh	Partner tidak boleh
Memindai QR untuk nomornya sendiri	Melihat atau mengunduh sesi, miliknya sekalipun
Menetapkan URL webhook & route check	Menyentuh MQTT dalam bentuk apa pun
Membuat & mencabut token aplikasinya	Melihat data akun lain
Melihat log pesan masuk/keluar akunnnya (baca-saja)	Mengubah jeda antar pesan, aturan hanya-balas-inbound, batas per tujuan
Mengatur timeout & maksimal percobaan dalam rentang yang ditetapkan superadmin	Menaikkan kuota hariannya sendiri
Memutuskan sesi WhatsApp-nya	Apa pun yang berkaitan dengan proses, <code>.env</code> , PM2, atau berkas
Melihat audit pairing akunnnya	Mendaftar mandiri tanpa verifikasi

Yang bisa diatur partner sengaja dibatasi pada hal yang **kalau disalahgunakan, yang rugi dirinya sendiri**.

11. Lampiran: integrasi partner berbasis Google Apps Script

Tiga sifat GAS mengubah rancangan. Semuanya sudah dikonfirmasi.

11.1 Cold start 2–5 detik ⇒ GAS tidak boleh dipakai untuk route check

Batas 2 detik pada route check **bukan** timeout per klien: gateway menyiarkan `wa/route/query/{app}` ke semua aplikasi terdaftar dan menunggu satu jendela bersama — dan jendela itu harus ditunggu penuh untuk mendeteksi ambiguitas. Menaikannya ke 10 detik berarti **setiap pesan dari kontak yang belum bersesi menunggu 10 detik**, termasuk pengguna kitaCatat dan AdaptLearn, gara-gara satu partner GAS. Dengan session TTL 30 menit, pengguna yang kembali setelah jeda membayar ongkos itu lagi.

Aturan: partner GAS memakai **daftar nomor** di konfigurasi klien (`caridenganNomor()`, dijawab lokal seketika), **bukan** `route_check_url`. Jalur HTTP route check hanya untuk klien berbasis-pengguna-dinamis dengan endpoint cepat — kitaCatat dan AdaptLearn.

Perbaikan murah yang tetap layak: jawaban route check yang **datang terlambat tetap disimpan ke cache**. Pesan pertama jatuh ke menu, pesan berikutnya sudah benar — bukan gagal selamanya.

11.2 doPost(e) tidak bisa membaca header ⇒ `webhook_auth_mode` per klien

Authorization: Bearer tidak akan pernah bekerja untuk GAS, dan web app GAS harus disetel dapat diakses siapa saja — sehingga tanpa token di tempat lain, siapa pun yang tahu URL-nya bisa mengirim pesan masuk palsu ke aplikasi partner.

Tambahkan opsi per klien, sejajar dengan `payload_format` yang sudah ada:

Mode	Untuk	Catatan
<code>header</code>	default, klien normal	seperti sekarang
<code>body</code>	GAS	token disisipkan ke dalam JSON payload, dibaca dari <code>e.postData.contents</code> . Paling mudah dinaikkan ke HMAC nanti
<code>query</code>	sedapat mungkin dihindari	token tercatat di log akses sepanjang jalur. Token <code>wa-api</code> sudah heksadesimal sehingga aman secara karakter di URL — masalahnya jejaknya, bukan encoding

11.3 Redirect GAS

URL `/macros/s/.../exec` lazimnya menjawab 302 ke `script.googleusercontent.com`. Karena itu aturan SSRF berbunyi **"ikuti maksimal satu redirect lalu validasi ulang tujuannya"** — bukan menolak redirect, dan bukan pula memberi Google pengecualian buta.

11.4 Kuota GAS bukan pengikat

`UrlFetch`: 20.000 panggilan/hari (akun konsumen), 100.000/hari (Workspace) — jauh di atas batas kita sendiri (`WARMUP_DAILY_LIMIT=500`, dan per akun akan lebih kecil). Partner GAS akan menabrak batas gateway jauh sebelum menyentuh kuota Google. Cukup dicatat di dokumentasi; yang dipantau sistem tetap kuota kita.

11.5 Jalur masuk aman

`WEBHOOK_TIMEOUT_MS` di `wa-api` adalah 15 detik dan dokumentasi sudah mensyaratkan webhook menjawab di bawah itu. Cold start 2–5 detik muat dengan ruang lega. Setelah Fase 7 (antrian webhook + retry), cold start yang sesekali melar pun tidak lagi berarti pesan hilang.

12. Rencana Fase

Fase 5 — Perbaikan fungsi yang mati, keselamatan operasional, & percobaan dua nomor

Kompleksitas: rendah. Risiko regresi: rendah. Nilai tertinggi per usaha.

1. **Jalur masuk pengguna baru** — alur `wa.me` berisi teks otomatis sehingga kontak baru mengirim pesan lebih dulu sebelum OTP/notifikasi. Pola yang sama dipakai ulang untuk onboarding partner (bagian 9).

2. **Alert kuota harian** — peringatan saat mendekati batas dan saat terjadi penolakan `warmup_daily_limit`. Menghapus satu-satunya kegagalan yang benar-benar senyap hari ini.
3. **Backup terverifikasi & terenkripsi** untuk `auth_session/`, `clients.json`, `data/gateway.db` — terjadwal, dengan retensi, **plus satu kali uji pemulihan sungguhan**. Backup yang belum pernah dipulihkan bukan backup.
4. **Retensi `message_log`** + alert ruang disk.
5. **Invalidasi `cache route check`** dari panel.
6. **Percobaan dua nomor** (*baru di v5.1*) — jalankan nomor kedua milik Anda sendiri, bukan partner, sebagai proses PM2 terpisah. Biarkan minimal satu minggu. Yang diukur:
 - RSS harian tiap proses — apakah stabil atau merangkak naik (sesi Baileys tumbuh mengikuti umur akun, jadi angka hari pertama menyesatkan);
 - beban CPU dan I/O SQLite saat dua socket aktif bersamaan;
 - **apakah LID seorang kontak sama di dua akun berbeda**. Ini menentukan apakah `identity_map` harus berkunci (`account_id`, `lid`). Kalau ya dan dikunci belakangan, pemetaan lama hilang — dan itu berarti `no_inbound_history` untuk semua kontak.

Prasyarat data: `pm2 status` + `pm2 describe` semua proses (memastikan bridge lama benar-benar mati); status backup yang berjalan sekarang; ukuran `gateway.db`, jumlah baris `message_log`, sisa disk; volume pesan nyata per hari.

Selesai bila: pengguna baru bisa mendaftar kitaCatat tanpa campur tangan manual; penolakan kuota memicu alert; pemulihan dari backup pernah dibuktikan sekali; jumlah nomor yang muat di X200MA punya dasar pengukuran, bukan tebakan.

Fase 6 — Durabilitas & kebenaran jalur keluar (P0)

Kompleksitas: sedang–tinggi. Risiko regresi: sedang.

Dikerjakan sebagai **satu paket** — T1, T2, retry, dan semantik `queued` saling mengunci; memperbaiki satu tanpa yang lain menghasilkan sistem yang setengah jujur.

1. **Tabel `outbound_messages`:** `request_id` (UNIQUE), `account_id`, `client_id`, `to_raw`, `target_jid`, `text`, `status`, `attempts`, `next_attempt_at`, `last_error`, timestamps. Siapkan kolom `delivered_at` / `read_at` **tanpa mengisinya** (bagian 13).
2. **`account_id` di seluruh jalur** (*baru di v5.1*) — `message_log`, `identity_map`, `sessions`, kunci rate limit (`account_id` + `jid`, bukan `jid` saja), dan dimensi topic MQTT. Sekarang isinya konstanta tunggal dan tidak ada perilaku yang berubah; nanti berarti membelah data yang sudah tercampur dan mengubah topic yang sudah dipakai kitaCatat dan AdaptLearn.
3. **Enqueue = tulis ke DB**; worker membaca dari DB, memori hanya cache.
4. **Idempotency:** `request_id` ganda tidak menghasilkan pengiriman kedua; ack lama dikirim ulang.
5. **Pemulihan saat start** untuk item `queued/processing` yang tertinggal, dengan penjagaan TTL dari K5.
6. **Retry untuk `send_error`** dengan backoff, terpisah dari retry rate limit.
7. **Dead-letter** setelah batas attempt atau lewat TTL, terlihat di panel.
8. **Graceful shutdown:** berhenti menerima, selesaikan atau kembalikan item berjalan ke status aman.
9. **Status akhir dapat ditanyakan** — sesuai K2.

Prasyarat data: keputusan K2, K4, K5, K9; volume outbound harian (dari Fase 5) untuk memperkirakan beban tulis.

Selesai bila: `pm2 restart wa-gateway` di tengah antrian tidak menghilangkan satu pesan pun; `request_id` sama dua kali menghasilkan satu pesan; kegagalan jaringan sesaat sembuh sendiri; pesan yang menyerah muncul di dead-letter, bukan lenyap.

Fase 7 — Durabilitas jalur masuk

Kompleksitas: sedang. Nilai setara P0.

Pesan masuk yang hilang berarti transaksi tidak tercatat dan pertanyaan tidak terjawab — sementara pengguna **mengira** sudah terkirim, dan tidak ada mekanisme apa pun yang memberi tahu siapa pun bahwa pesan itu pernah ada.

1. **Persist inbound event** sebelum diteruskan — ini yang menutup lubang clean session (K3) tanpa mengubah sesi MQTT.
2. **Antrian webhook + retry berjenjang** menggantikan `catch { log.error }`.
3. **event_id pada payload webhook** supaya aplikasi bisa menolak duplikat. Perlu dicek lebih dulu apakah penerima `payload_format: fonnte_like` mengabaikan field tak dikenal — kemungkinan besar ya, **tapi jangan diasumsikan**.
4. **webhook_auth_mode** (`header / body / query`) — bagian 11.2.
5. **Penjagaan SSRF** pada URL webhook & route check — bagian 8.1. Wajib selesai **sebelum** partner pertama masuk.
6. **Dead-letter inbound** + tampilan di panel untuk meneruskan ulang manual.

Prasyarat data: kode penerima webhook kitaCatat (`webhook/receive.php`) dan AdaptLearn (`api/wa_webhook.php`) — perilaku terhadap field tak dikenal, dan apakah pemrosesan sudah idempoten terhadap `message_id` yang sama.

Selesai bila: aplikasi tujuan dimatikan 10 menit, semua pesan yang masuk selama itu tetap sampai setelah hidup kembali; pesan yang sama tidak diproses dua kali; URL webhook yang mengarah ke jaringan internal ditolak.

Fase 8 — Keterlacakan & observability

Kompleksitas: rendah-sedang.

1. **Correlation ID** mengalir dari `wa-api` → MQTT → gateway → antrian → log → ack.
2. **message_log diperluas** (`request_id, message_id, account_id`, alasan kegagalan) atau digantikan `message_events`.
3. **Metrik yang paling berguna:** `queue_depth` dan `queue_oldest_age` **per akun** — keduanya mengungkap kondisi "kelihatan hidup tapi menumpuk" yang tidak terdeteksi heartbeat.
4. **/ready yang jujur:** MQTT tersambung **dan** WhatsApp tersambung **dan** DB bisa ditulis. Watchdog memantau `/ready`, bukan `/health`.
5. **Panel:** antrian berjalan, umur item tertua, dead-letter, penelusuran satu `request_id`.

Selesai bila: satu `request_id` bisa ditelusuri dari HTTP sampai terkirim tanpa membuka lima log; backlog memicu alert sebelum pengguna mengeluh.

Fase 9 — Ketahanan operasional (**gerbang menuju Level 2**)

Kompleksitas: rendah, tapi memakan waktu. Ini yang membuktikan Fase 6–8 benar-benar bekerja.

1. **Uji kegagalan terjadwal** (bagian 14), dijalankan sungguhan, hasilnya dicatat.
2. **Uji pemulihan penuh** dari backup terenkripsi ke sistem berjalan, diukur waktunya.
3. **Compatibility matrix** Baileys ↔ Node ↔ versi WhatsApp Web yang teruji — syarat sebelum menyentuh Baileys 7.x.
4. **Prosedur insiden tertulis**: logout 401, blokir nomor, korupsi DB, disk penuh, restart loop. Termasuk pertanyaan yang belum terjawab: **kalau nomor diblokir, apa rencananya?**
5. **Daftar aplikasi dinamis** supaya menambah klien tidak menuntut restart gateway — operasi yang sudah pernah memicu insiden.

Syarat masuk Level 2: seluruh matriks uji lulus, **dan** sistem berjalan tenang beberapa minggu tanpa intervensi.

Fase 10 — Multi-akun & portal partner (Level 2)

Dimulai hanya setelah Fase 9 lulus.

Urutan dari yang paling murah dan paling menutup risiko:

1. **Pemisahan proses panel**: **wa-ui** superadmin (Tailscale, memegang **ops.js**) dan **portal-partner** (127.0.0.1, tanpa **ops.js**).
2. **Cloudflare Access + validasi JWT** di portal partner. Verifikasi ulang **backup.simbiot.id** dan **waapi.simbiot.id** masih hidup setelah perubahan **/etc/cloudflared/config.yml** — blok baru **wajib** sebelum **http_status:404**.
3. **Model akun**: **accounts** (id, nama, status, kuota, batas), relasi ke klien API, **expires_at** / **revoked_at** / **last_used_at** pada token.
4. **Satu proses gateway per akun**, sesi terpisah, antrian terpisah, sakelar mati per akun.
5. **Topic MQTT & ACL per akun**, termasuk topic QR.
6. **Portal partner**: QR + pairing, token, webhook & route check, log baca-saja, audit pairing.
7. **Registrasi GAS + verifikasi manual** (bagian 9).
8. **Kuota & rate limit per akun**, ditegakkan di antrian.
9. **Audit log** per akun.
10. **Dokumentasi partner** — termasuk pernyataan terbuka tentang sisa risiko (bagian 8.2).

Selesai bila: satu partner bisa onboarding penuh tanpa Anda menyentuh terminal, kecuali langkah verifikasi manual yang memang disengaja.

Fase 11 — Level 3 (**ditunda**)

Tidak direncanakan sekarang. Dievaluasi ulang hanya setelah Level 2 teruji waktu dan banyak kasus. Catatan untuk evaluasi nanti: yang menghalangi Level 3 bukan arsitekturnya — itu justru selesai dengan multi-akun. Yang menghalangi adalah **kustodian sesi** dan **ketergantungan pada satu operator** (bagian 8.2), dan keduanya tidak selesai dengan menulis kode.

13. Yang sengaja tidak dikerjakan

Tidak dikerjakan	Alasan
Rewrite	Struktur sudah benar; masalahnya durabilitas
Pindah ke PostgreSQL	Belum ada pemicu; SQLite + WAL cukup
Kubernetes / container	Menambah lapisan kegagalan pada mesin 1,8 GB
DELIVERED / READ	Beban tulis terus-menerus, manfaat kecil. Kolomnya disiapkan, tidak diisi
Memindahkan <code>clients.json</code> ke SQLite	Keputusan lama beralasan (jumlah kecil, terbaca manusia, tanpa modul native). Belum ada yang berubah
Baileys 7.x	Menunggu stable dan compatibility matrix (Fase 9)
Fitur WhatsApp baru (media, tombol, grup)	Ditahan sampai Fase 6–7 selesai
Multi-node / HA	Satu nomor tidak bisa dilayani dua proses sekaligus — HA-nya semu
Pendaftaran partner otomatis	Verifikasi manual adalah kontrol utama, bukan kelambatan

14. Matriks uji kegagalan

Kegagalan yang disuntikkan	Perilaku yang diharapkan	Diuji setelah
<code>pm2 restart wa-gateway</code> saat antrian berisi	Tidak ada pesan hilang	Fase 6
<code>kill -9</code> pada gateway	Sama	Fase 6
<code>request_id</code> sama dikirim dua kali	Satu pesan terkirim	Fase 6
WiFi putus 2 menit saat mengirim	Sembuh sendiri, bukan <code>failed</code>	Fase 6
Aplikasi tujuan mati 10 menit	Pesan masuk tetap sampai	Fase 7
Webhook menjawab 500 terus	Dead-letter + alert	Fase 7
<code>wa-api</code> mati 30 detik saat ada pesan masuk	Pesan tidak hilang	Fase 7
Webhook diarahkan ke <code>127.0.0.1</code> / IP Tailscale	Ditolak sebelum dipanggil	Fase 7
Mosquitto di-restart	Semua proses tersambung kembali	sekarang
Kuota harian tercapai	Alert, bukan diam	Fase 5
Disk hampir penuh	Alert sebelum berhenti	Fase 5

Kegagalan yang disuntikkan	Perilaku yang diharapkan	Diuji setelah
Sesi WhatsApp logout (401)	Alert + QR muncul di panel	sekarang (verifikasi ulang)
DB dipulihkan dari backup terenkripsi	Layanan berjalan lagi, waktu terukur	Fase 5
Nomor diblokir WhatsApp	Prosedur tertulis dijalankan	Fase 9
Portal diakses tanpa melewati Access	Ditolak (JWT tidak valid)	Fase 10
Akun A mencoba membaca data akun B	Ditolak	Fase 10
Satu akun kena logout	Akun lain tidak terpengaruh	Fase 10

15. Data yang harus dikumpulkan lebih dulu

Jangan diasumsikan — perlu diambil dari mesin:

1. `pm2 status` + `pm2 describe` setiap proses.
2. Apakah ada backup yang berjalan sekarang, apa isinya, kapan terakhir diuji.
3. Ukuran `data/gateway.db`, jumlah baris `message_log`, sisa disk.
4. Volume pesan nyata per hari (inbound & outbound).
5. Struktur `clients.json` (tanpa hash) — berapa klien, berapa yang punya webhook.
6. Kode penerima webhook kitaCatat & AdaptLearn (untuk Fase 7 poin 3).
7. Hasil percobaan dua nomor: RSS harian, dan **apakah LID sama di dua akun**.
8. Jawaban K2, K4, K5, K9.

16. Ringkasan urutan

```

Fase 5   Perbaiki yang mati + backup + alert kuota + percobaan 2 nomor
↓
Fase 6   Antrian keluar durable, idempoten, jujur (+ account_id di skema)
↓
Fase 7   Jalur masuk durable + webhook retry + penjagaan SSRF
↓
Fase 8   Correlation ID + metrik + /ready + panel
↓
Fase 9   Uji kegagalan, uji pemulihan, prosedur insiden ← gerbang Level 2
↓
Fase 10  Multi-akun + portal partner (Cloudflare Access) ← Level 2
↓
Fase 11  Level 3 – ditunda, dievaluasi ulang nanti

```

Prinsip penutup: tidak ada partner yang masuk sebelum sistem satu-akun terbukti bisa kehilangan daya, kehilangan jaringan, dan di-restart tanpa kehilangan pekerjaan. Menambah partner ke sistem yang belum tenang berarti menambah orang yang terdampak setiap kali ada yang salah.